

NEWSLETTER N. 506 of July 17, 2023

App for toll reimbursement: the Authority fines Aspi 1 million euros

Fidelity card: the Authority fines Rinascente 300,000 euros

Journalism: the Authority intervenes to protect minors

Healthcare: Authority sanctions Medical Center for data exchange of two patients

App for toll reimbursement: the Authority fines Aspi 1 million euros

Misclassification of privacy roles

A fine of 1 million euros has been imposed by the Privacy Authority on Autostrade per l'Italia S.p.A. (ASPI) for unlawfully processing the data of approximately 100,000 users registered with the toll reimbursement app, named Free to X.

The service's critical issues - which allows for the total or partial refund of the highway ticket cost due to delays caused by construction sites - were reported to the Authority by a consumer association. The Authority established that Autostrade acts as the data controller and not as the processor, as indicated in the documentation governing the relationships between Aspi and the company Free to X, which developed and manages the app, as well as in the information provided to users regarding this matter.

It was Aspi, in its capacity as the concessionaire of the highway network, that identified the reimbursement mechanism, the nature of the compensatory measures, the fulfillment methods, and the type of delay related to the presence of construction sites, assigning Free to X only the tasks of implementing the service. The misclassification of the privacy roles held by the two companies - the Authority emphasizes - has immediate repercussions on the information provided to users, which was therefore not correctly formulated. The information should have included the actual identity of the data controller, namely Aspi, as well as all additional information to ensure correct and transparent processing, as required by the Regulation. Aspi also incurred an additional violation for failing to designate Free to X as the data processor.

The Authority did not indicate corrective measures to Aspi as the company complied with privacy regulations during the proceedings.

Fidelity card: the Authority fines Rinascente 300,000 euros

Numerous violations found in the processing of customer data

The Privacy Authority has fined Rinascente S.p.A. 300,000 euros for unlawfully processing personal data of millions of customers in marketing and profiling activities through the use of loyalty cards.

The Authority intervened following a report from a customer who, after an altercation with a store employee, had her loyalty card issued years ago canceled and a new, unsolicited one activated, which contained offensive references in the header regarding the complainant. The lady complained that, in fact, to introduce the new offensive header, an unauthorized access to the customer file had been made.

In addition to this violation of the principles of integrity and confidentiality, fairness, and legality, the inspection carried out at the Rinascente headquarters by the Special Privacy and Technological Fraud Unit of the Guardia di Finanza revealed other non-compliance with data protection regulations.

During the investigation, it was found, for example, that the information related to the loyalty card named "friendscard" did not specify the retention periods of data for marketing and profiling purposes. Furthermore, the activities carried out through Facebook-Meta, which involved forwarding customers' email addresses to the American company, were not indicated.

Finally, regarding the e-commerce activity present on the site: despite conducting extensive profiling activities, it was found that Rinascente had not established the impact assessment procedure required by the GDPR.

The Authority has instructed the company to define differentiated retention periods, distinguishing between processing for marketing purposes and processing for profiling purposes, and to delete or anonymize data that should be retained beyond the established terms. In determining the amount of the fine at 300,000 euros, the Authority considered the large number of individuals involved in the violations (more than 2,000,000 people were found to be registered in stores or online), their duration, and the economic capacity of the Company. Mitigating factors included the absence of previous

proceedings against the Company, the timely adoption of corrective measures, and the ongoing severe socio-economic crisis.

Journalism: the Authority intervenes to protect minors

Fines imposed on a newspaper and two information websites.

The Privacy Authority has sanctioned a newspaper and two news websites that had unlawfully published personal data and details of a child and a minor girl involved in two different news incidents. In both cases, the Authority acted following complaints from the respective parents.

In the new intervention to protect minors, the Authority reiterated that journalists in their activities are required to comply with the Ethical Rules and the new Treviso Charter, which provide enhanced protections and guarantees for minors. These rules impose that journalists, even in the presence of facts of public interest, refrain from disseminating personal data and excessive details that make minors identifiable, particularly in cases of death due to illness.

In the first incident, in fact, “La Nazione” had published, in both the print and online versions, two articles that reported an excessive amount of data: the personal details of the deceased child, the alleged illness he suffered from, and a photo of the coffin; the identifying data (name and surname, profession, residence) of the father and mother; the name and age of the younger sister.

In the second case, the Authority noted that the online newspaper “Torino Oggi” had published an article, with a negatively slanted title, containing two photographs and a video made by a journalist depicting a minor at an unauthorized gathering interrupted by the arrival of the police. The video footage had been taken from a distance that allowed for the identification of the individuals present, despite their attempts to avoid being recognized. The video was also published on the YouTube channel of the publisher of the newspaper.

To the publishers of the two outlets, who during the investigation removed the articles, photos, and video from the Internet, the Authority imposed fines of 30,000 and 5,000 euros, respectively, along with a prohibition on any further processing of the minors' data, even online, including the historical archive. For the publication of an article, also related to the case of the deceased child, the Authority applied a fine of 10,000 euros to the publisher of “la Voce Apuana”.

Health: Authority sanctions Medical Center for exchanging data of two patients

Violated the principle of accuracy and integrity

Healthcare facilities must adopt all appropriate technical and organizational measures to ensure that the processing of patients' personal data complies with privacy regulations. This was reiterated by the Authority for the protection of personal data when imposing a fine of 10,000 euros on a Medical Center that had exchanged the data and health information of two namesake patients in its database.

The Authority had acted following a complaint from one of the two affected patients, who reported receiving periodic SMS reminders for medical visits never requested on his private number and finding invoices of about 4,000 euros issued with his tax code for services never rendered in his tax return. In the report, the patient highlighted that he had repeatedly asked the clinic to resolve the issue, without any outcome.

From the Authority's investigation, it emerged that the event occurred due to the presence of two namesake individuals in the facility's database. This homonymy had thus contributed to an incorrect attribution of the tax code and residence address at the time of the delivery of some invoices. The attribution error had also caused the sending of automatic SMS messages to the complainant instead of to the patient to whom they were actually addressed.

Numerous violations were therefore identified. The Center had indeed processed data in violation of the principles of accuracy, integrity, and confidentiality by not correctly recording the data of the two patients in the database. It had also communicated health-related data in the absence of a suitable legal basis, in violation of the basic principles of the European Regulation and security obligations.

Considering the limited scope of the processing and the fact that it was a single case, the Authority

imposed a fine of 10,000 euros on the Medical Center.

THE ACTIVITIES OF THE AUTHORITY - FOR THOSE WHO WANT TO KNOW MORE

The most important interventions and measures recently adopted by the Authority
Pornhub under the scrutiny of the Privacy Authority. The Authority requests clarifications on user
profiling and tracking systems - Press release of 13.07.2023

On July 10, the European Commission adopted the adequacy decision regarding the EU-US
framework agreement – 12.07.2023

Report on activities 2022. Summary for the press, text of the Report, and Speech of the President –
6.7.2023

NEWSLETTER of the Authority for the protection of personal data (Reg. at the Court of Rome no. 654
of November 28, 2002).

Responsible Director: Baldo Meo.

Direction and editorial office: Authority for the protection of personal data, Piazza Venezia, no. 11 -
00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it